ISSN(Print) : 1976-5304, ISSN(Online) : 2713-931X
https://kdfs.jams.or.kr, DOI: 10.22798/kdfs.2024.18.2.36

Windows 환경에서의 iCloud 인증 정보 추출 및 활용에 관한 연구

김 재 욱*, 김 준 호**, 박 정 흠***
고려대학교 일반대학원 정보보안학과 (대학원생)*, 고려대학교 정보보호대학원 (대학원생)** (부교수)***

A Study on extracting and utilizing iCloud authentication information in Windows environments

Jaeuk Kim*, Junho Kim, Jungheum Park*****
Dept. of Information Security, Graduate School, Korea University (Graduate Student)*, School of Cybersecurity, Korea University (Graduate Student), (Associate Professor)*****

요 약

iCloud는 사진, 파일, 동영상과 같은 데이터들을 클라우드에 안전하게 저장하고, 모든 기기에서 최신 상태로 유지할 수 있도록 해주는 Apple의 핵심 서비스이다. 높은 인지도와 범용성을 가진 iCloud는 Windows 환경에서도 자주 사용된다. 디지털포렌식 관점에서 수사관이 사용자의 iCloud 계정에 로그인할 수 있으면 본 계정과 연동된 모든 Apple 서비스에 접근할 수 있어 수사에 도움이 될 수 있다. 그러나 iCloud는 일반적으로 계정에 등록된 또 다른 Apple 기기를 통한 추가적인 2단계 인증을 요구하며, 수사 현장에서 이를 위한 기기를 확보하는 상황을 항상 기대하기는 어렵다. 따라서 이러한 추가적인 인증 과정을 거치지 않고 iCloud 계정에 접근할 수 있는 실용적인 방안에 대한 연구가 필요하다. 본 논문에서는 Windows 환경에서의 활성 및 비활성 상태의 시스템 관점에서 iCloud 인증 정보(ID, 패스워드, 브라우저 신뢰토큰, PCS 세션)를 추출하는 방법을 소개하고, 이를 반영하여 2단계 인증을 우회할 수 있는 iCloud 디지털포렌식 수사 절차를 제안한다. 그리고 가상 시나리오 구성을 통해 제시한 절차의 타당성과 실현 가능성을 종합적으로 평가한다.

주제어 : 디지털포렌식, 온라인 서비스, iCloud 인증 정보, 복호화, 물리 메모리

ABSTRACT

iCloud is Apple's core service that securely stores data such as photos, files, and videos in the cloud and keeps them up to date on all devices. With high recognition and versatility, iCloud is commonly used even in Windows environments. From a digital forensics perspective, if investigators can log into a user's iCloud account, they can access all Apple services associated with that account, which can aid investigations. However, iCloud typically requires additional two-factor authentication via another Apple device registered to the account, making it difficult to always anticipate securing such a device for access in investigative scenarios. Therefore, research is needed into practical methods for accessing iCloud accounts without undergoing these additional authentication processes. This paper introduces a method for extracting iCloud authentication information (ID, password, browser trust token, PCS sessions) from both live and dead system in Windows environments, and proposes an iCloud digital forensics investigation procedure that circumvents two-factor authentication based on this extraction. It comprehensively evaluates the feasibility and practicality of the proposed procedure through virtual scenario construction.

Key Words : Digital Forensics, Online Services, iCloud Authentication Information, Decryption, Physical Memory

Ⅰ. 서 론

최근 클라우드 기술이 발전하면서 우리 삶에 많은 변화를 가져왔다. 사람들은 클라우드 기술을 활용하여 대용량 데이터를 원격지에 저장하거나 하나의 파일을 다른 사람들과 공유하여 효율적으로 업무를 수행한다. 또한 클라우드 서버와의 동기화 기능을 사용하여 연동된 기기 사이에 다양한 데이터를 주고받는다.

iCloud는 Apple에서 개발한 클라우드 서비스로 사진, 파일, 동영상과 같은 데이터들을 원격지에 안전하게 저장하고, 모든 기기에서 최신 상태로 유지할 수 있도록 해주는 Apple의 핵심 서비스이다. Apple은 iCloud 계정을 메일, 연락처 등과 같은 다른 서비스와 호환될 수 있도록 만들어 사용자들이 다양한 Apple 서비스를 하나의 계정으로

※ 이 논문은 2024년도 정부(문화체육관광부)의 재원으로 한국저작권보호원의 지원을 받아 수행된 연구임(No 2024. 저작권 특화 디지털포렌식 전문인력 양성사업)
- Received 06 April 2024, Revised 29 April 2024, Accepted 25 May 2024
- 제1저자(First Author) : Jaeuk Kim (Email : zzxx3081@naver.com)
- 교신저자(Corresponding Author) : Jungheum Park (Email : jungheumpark@korea.ac.kr)

이용할 수 있도록 설계했다. iCloud는 이와 같은 높은 인지도와 범용성으로 Windows 환경에서도 자주 사용된다.

디지털포렌식 관점에서 수사관이 iCloud 계정에 로그인할 수 있는 경우, 이와 연동된 다른 Apple 서비스에 접근할 수 있어 수사에 유용하게 활용할 수 있다. 그러나 iCloud는 기본적으로 1단계 및 2단계 인증을 요구하기 때문에 수사관의 입장에서 계정에 접근하는 것은 쉬운 일이 아니다. 1단계 인증은 계정의 ID와 비밀번호를 활용하여 로그인하는 과정이며 2단계 인증은 계정과 연동된 디바이스로 전송된 6자리 랜덤 코드를 입력하는 과정이다. 즉, 포렌식 수사관이 iCloud에 로그인하기 위해서는 2단계 인증을 할 수 있는 추가적인 Apple 디바이스를 확보해야 한다. 만약 기기를 확보하지 못하였거나, 확보하였더라도 기기에 잠금이 걸려있는 경우, 수사관은 2단계 인증 코드를 확인할 수 없어 계정에 로그인할 수 없다. Magnet Forensics 社의 Magnet AXIOM[1]의 경우, iCloud 포렌식 기능을 제공하지만, 사용자 계정에 접근하기 위해 2단계 인증 코드를 필요로 한다. 결론적으로, iCloud 사용자 데이터에 접근하기 위해서는 2단계 인증을 지원하는 기기를 확보해야 한다는 한계점이 존재한다.

본 논문에서는 Windows 환경의 활성 및 비활성 상태의 시스템에서 로컬 저장소 및 물리 메모리 분석을 통해 2단계 인증을 우회할 수 있는 iCloud 인증 정보 추출 방법에 대해 소개한다. 그리고 이를 반영한 iCloud 디지털포렌식 수사 절차를 제안하고, 가상 시나리오 구성을 통해 타당성과 실현 가능성을 종합적으로 평가한다.

이후의 구성은 다음과 같다. 2절에서는 Windows DPAPI 및 iCloud 서비스의 자격 증명에 대한 배경지식을 설명하고, 3절에서는 크로미움 데이터 복호화 및 클라우드 메모리 포렌식을 다룬 이전 연구들을 언급한다. 4절에서는 iCloud 인증 정보를 추출하는 방법론을 소개하고, 이를 통해 사용자 데이터에 접근할 수 있는 디지털포렌식 수사 절차를 제안한다. 5절에서는 iCloud 인증 정보 추출 및 사용자 데이터 접근 관련 가상 시나리오를 설계하고, 절차 검증 평가 문항을 제시하여 4절에서 제안한 방법론의 타당성 및 실현 가능성을 종합적으로 평가한다. 마지막 6절에서는 결론과 향후 발전 방향을 기술한다.

Ⅱ. 배경 지식

본 절에서는 iCloud 인증 정보 추출에 필요한 기술과 iCloud 서비스의 자격 증명에 대한 배경지식을 다룬다.

2.1. Windows DPAPI

Windows DPAPI는 “Windows Data Protection API”의 약어로 Windows 운영체제에서 제공하는 암호화 서비스를 구성하는 CryptAPI의 한 종류이다. Windows 자격 증명은 DPAPI를 통해 사용자 인증 정보(웹사이트 비밀번호, 자동 로그인 쿠키, 크로미움 암호화 키 등)를 암호화하여 저장해두었다가 필요시 복호화하여 사용자 인증을 시도한다. 활성 상태 시스템에서는 CryptProtectData 및 CryptUnprotectData API를 호출하여 사용자의 인증 정보를 암호화하거나 복호화할 수 있다. 반면, 비활성 상태 시스템에서는 Windows 로컬 계정 비밀번호의 SHA-1 값, 사용자 GUID 파일 그리고 SID 값을 이용해 DPAPI 마스터키를 획득한 후, 이를 통해 암호화된 사용자 인증 정보를 복호화한다. 아래 〈Figure 1〉은 Windows 로컬 계정에 대한 비활성 상태 시스템에서 DPAPI 사용자 인증 정보를 복호화하는 순서도를 나타낸 것이다. 해당 알고리즘은 기존 연구[2]에서 오픈 소스(dpapick3)로 공개되어 있다. Windows 로컬 계정 비밀번호의 경우, Impacket[3]을 활용하여 SAM, SYSTEM 레지스트리에서 NTLM 해시 값을 추출한 후, 비밀번호 크래킹[4]을 통해 획득이 가능하다.

〈Figure 1〉 Decryption steps of DPAPI-protected data stored on a Windows system with a local account

한편, 클라우드 기술이 발전하면서 계정 연동 및 동기화 등의 이유로 Windows 로컬 계정 대신 Microsoft 계정을 사용하는 경우가 있어 이에 대한 고려가 필요하다. Microsoft 계정 시스템의 경우, 활성 상태에서는 동일한 CryptAPI를 통해 사용자 인증 정보의 암복호화가 가능하지만, 비활성 상태에서는 SHA-1 값을 계산하는 방법이

〈Figure 1〉과 다르다. 아래 〈Figure 2〉는 Microsoft 계정에 대한 비활성 상태 시스템에서 DPAPI 사용자 인증 정보를 복호화하는 순서도를 나타낸 것이다. 계정 비밀번호의 SHA-1 값을 그대로 사용하는 Windows 로컬 계정 시스템과 다르게 Microsoft 계정 시스템은 계정 비밀번호와 Microsoft CacheData 파일을 조합한 별도의 알고리즘을 사용하여 SHA-1 값을 계산한다. 해당 알고리즘은 공개된 정보가 부족하여 본 연구를 위해 Nirsoft 社의 MadPassExt[5]를 역분석하여 파악했다.

〈Figure 2〉 Decryption steps of DPAPI-protected data stored on a Windows system with a Microsoft account

〈Figure 2〉 내 CacheData 파일은 Microsoft 계정을 컴퓨터에 처음 등록할 때 자동으로 생성되는 바이너리 파일이다. Microsoft 계정 시스템의 SHA-1 값은 이 파일에 저장된 DPAPI password[5] 값의 SHA-1 값을 의미한다. 아래 〈Table 1〉은 CacheData 파일의 경로를 나타낸 것이다.

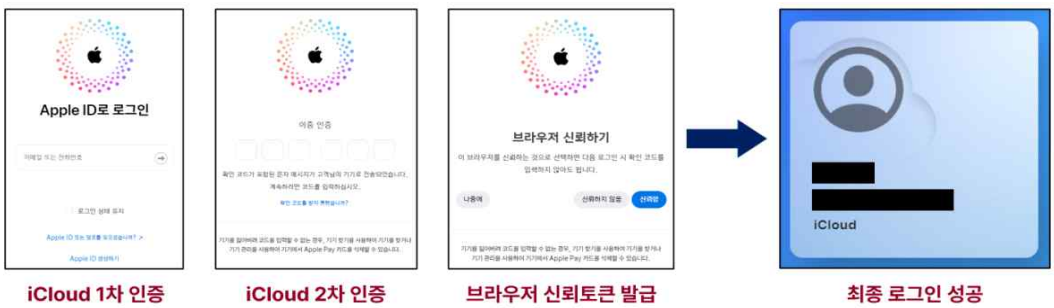
〈Table 1〉 Full path of a CacheData file for a Microsoft account

No.	Microsoft CacheData file path	Description
1	%SystemRoot%\System32\config\systemprofile\AppData\Local\Microsoft \Windows\CloudAPCache\MicrosoftAccount\{Account ID}\Cache\CacheData	CacheData 파일 경로

DPAPI password 값은 AES-CBC 알고리즘으로 암호화되어 있으며 암호문 위치는 CacheData 파일 오프셋 0x48의 값에 따라 달라진다. 해당 값이 0x02인 경우, 암호문의 위치는 오프셋 0xB0가 되고, 해당 값이 0x03인 경우, 암호문의 위치는 0xC4가 된다. 암호문의 처음 4바이트는 암호문 전체 길이를 나타내며 다음 16바이트는 IV(Initial Vector)가 된다. 실제 암호문은 그 이후부터 시작된다. AES-CBC 복호화 키는 Microsoft 계정 비밀번호를 UTF-16LE으로 인코딩한 후, PBKDF2-HMAC-SHA256 알고리즘을 10000번 반복하여 파생한 값이다. 즉, Microsoft 계정 비밀번호를 통해 CacheData 파일에 저장된 DPAPI password 값을 복호화한 후, SHA-1 값을 계산한다. 이후 과정은 〈Figure 1〉과 동일하다.

2.2. iCloud 서비스의 자격 증명

API는 "Application Programming Interface"의 약어로 소프트웨어 응용 프로그램이 서로 상호 작용하기 위한 인터페이스를 제공하는 도구나 규약을 가리킨다. Internal API란, 사용자에게 공개되어 있지 않은 API로 개발자 수준의 모든 서비스 기능을 지원하는 API을 의미한다[6]. iCloud 서비스의 사용자 인증은 Internal API를 활용한 자격 증명 데이터 송수신을 통해 이루어진다. 아래 〈Figure 3〉은 iCloud 웹사이트에서 로그인하는 과정을 나타낸 것이다. iCloud 서버는 API 통신을 통해 사용자의 신원을 확인한 후, 최종 로그인 인증 세션인 PCS 세션[7]을 발급한다.



〈Figure 3〉 Authentication steps for accessing the iCloud website

MauriceConrad[7]는 iCloud Internal API를 오픈 소스로 공개했다. 아래 〈Table 2〉는 로그인에 관련된 Internal API를 나타낸 것이다. 본 절에서는 알려진 iCloud Internal API와 사용자 인증 정보를 활용하여 iCloud 계정에 접근할 수 있는 3가지 방법에 대해 설명한다.

〈Table 2〉 Internal APIs for iCloud authentication

No.	iCloud Internal API URL	Description
1	idmsa.apple.com/appleauth/auth/signin	iCloud 1단계 인증
2	idmsa.apple.com/appleauth/auth/verify/trusteddevice/securitycode	iCloud 2단계 인증
3	idmsa.apple.com/appleauth/auth/2sv/trust	브라우저 신뢰토큰 발급
4	setup.iCloud.com/setup/ws/1/accountLogin	최종 로그인 인증(PCS 세션 요청)

2.2.1. 1단계 인증 + 2단계 인증

iCloud는 〈Figure 3〉과 같이 1단계 및 2단계 인증을 통해 로그인이 가능하다. 1단계 인증은 계정 ID와 비밀번호 입력을 통해 이루어지며 인증에 성공할 경우, 2단계 인증 페이지로 넘어가게 된다. 2단계 인증은 랜덤 숫자 코드 6자리를 입력하는 절차로 인증 코드는 iCloud 계정과 연동된 사용자의 디바이스로 전송되는 특징이 있다. 디지털포렌식 관점에서 iCloud 계정에 로그인하여 사용자 데이터에 접근하기 위해서는 2단계 인증을 지원하는 사용자의 또 다른 Apple 기기가 필요하다.

2.2.2. 1단계 인증 + 브라우저 신뢰토큰

2.2.1절과 같이 iCloud는 기본적으로 2단계 인증을 요구한다. 그러나 사용자가 과거에 웹 브라우저로 로그인하여 브라우저 신뢰토큰을 발급받았을 경우, 1단계 인증만을 통해 로그인이 가능하다. 브라우저 신뢰토큰이란, 사용자가 매번 iCloud를 로그인할 때마다 2단계 인증을 해야 하는 불편함을 해소하기 위해 iCloud에서 발급하는 토큰을 의미한다.

2.2.3. PCS 세션을 통한 로그인

〈Table 2〉의 최종 로그인 인증 API(setup.iCloud.com/setup/ws/1/accountLogin)는 PCS 세션을 요청하는 Internal API를 의미한다. iCloud 서버는 1단계 인증과 2단계 인증 그리고 브라우저 신뢰토큰의 유효성을 검증하여 사용자의 신원을 확인한 후, 클라이언트에게 PCS 세션을 발급한다. 즉, 사용자가 iCloud 최종 로그인에 성공할 경우, 서버로부터 PCS 세션을 발급받을 수 있다. 해당 세션은 물리 메모리 내 웹 브라우저 프로세스에 존재하는 정보로 로컬 저장소에는 일반적으로 저장되지 않는다. 하지만 iCloud 1단계 인증 페이지에서 "로그인 상태 유지" 옵션을 설정한 경우, 로컬 저장소에 저장하여 사용할 수 있다. iCloud에 연동된 모든 서비스에 대한 API 통신은 이 세션 값을 매개로 작동한다. MauriceConrad[7]가 공개한 오픈 소스의 경우, iCloud 최종 로그인에 성공했을 때 발급받은 PCS 세션 정보를 파일로 저장하는 기능이 존재한다. 하지만 PCS 세션의 세부적인 구조 및 설명에 대한 언급이 없으며 이를 메모리 포렌식 관점에서 수집하고, 활용할 수 있는 방법에 대한 내용은 다루지 않았다. 따라서 본 논문에서는 물리 메모리 분석을 통해 사용자의 PCS 세션 값을 탐지하고, 이를 디지털포렌식 수사에 활용할 수 있는 방법을 제안한다. 결과적으로 PCS 세션 획득이 가능할 경우, iCloud 로그인 프로세스를 거치지 않고, 사용자 데이터에 직접적으로 접근할 수 있게 된다.

Ⅲ. 관련 연구

Oestreicher, K.[8]는 macOS 시스템에서 iCloud 동기화 서비스를 통해 획득한 파일과 원본 파일의 해시값, 메타데이터 그리고 타임스탬프의 변경 여부를 비교하여 데이터 무결성에 대한 상관관계를 제시하고, iCloud 동기화 데이터가 디지털 증거로 활용될 수 있음을 보였다.

Ahmad, N. H. 등[9]은 Windows 7 환경에서 pCloud에 대한 물리 메모리 아티팩트를 분석하였다. 저자는 VirtualBox[10]를 통해 가상 환경에서 pCloud 계정 로그인, 파일 업로드, 파일 다운로드 등의 사용자 행위를 수행하는 시나리오를 구성한 후, 메모리 덤프를 통해 계정 정보, 업로드한 파일의 메타데이터, 파일 다운로드 시간 등

의 포렌식적 아티팩트가 발견될 수 있음을 보였다.

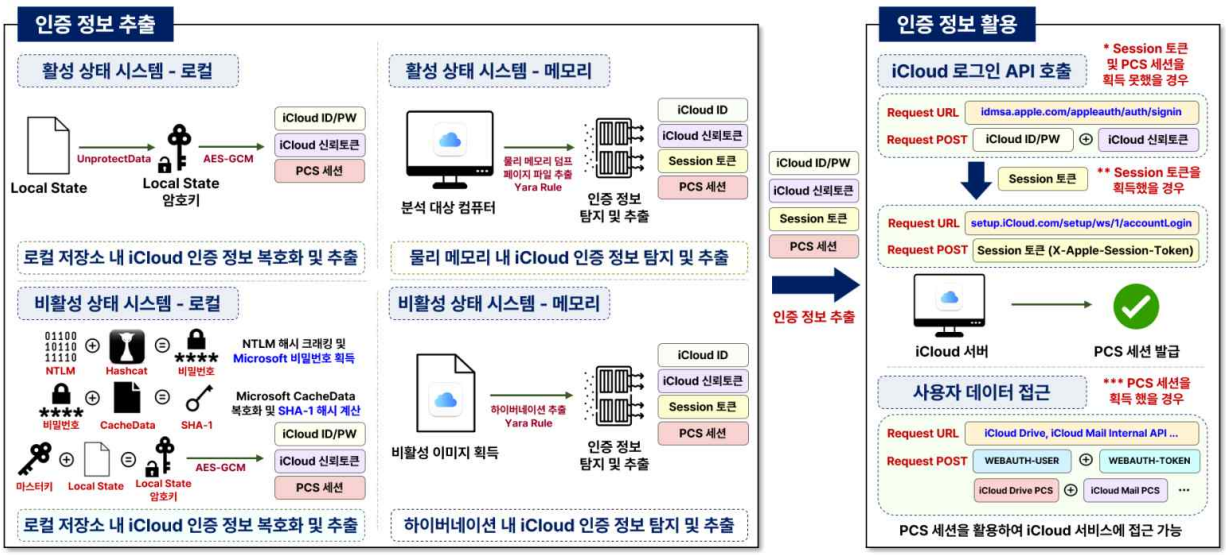
Sumin, B. 등[11]은 Windows 10 환경에서 "빠른 시작 켜기"가 활성화된 상태에서 시스템 종료 시 생성되는 하이버네이션 파일에 대한 메모리 포렌식 방법을 소개하고, 사례 연구를 통해 시스템 종료 직전 행해진 외부 저장장치로의 파일 복사 흔적을 추적하는 방안을 제시했다.

Jihyeok, Y. 등[6]은 Open API와 Internal API를 활용하여 클라우드 사용자 데이터를 수집하는 CATCH 프레임워크를 제안했다. Microsoft OneDrive 사례 연구를 통해 Internal API를 활용할 경우, 기존에 잘 알려진 디지털포렌식 상용도구들보다 더 많은 종류의 사용자 아티팩트를 수집할 수 있음을 보였다.

Uk, H. 등[12]은 Windows 환경에서 주로 사용되는 25개의 웹 브라우저들을 대상으로 로컬 저장소에 존재하는 사용자 인증 정보 및 자동 로그인 쿠키 데이터를 다른 시스템으로 옮겨와 인증 권한을 획득하는 데이터 마이그레이션 실험을 진행했다. CryptProtectData 및 CryptUnprotectData API를 통해 DPAPI로 암호화된 자격증명 데이터를 복호화한 후, 분석용 활성 상태 시스템의 DPAPI를 이용하여 다시 암호화하여 동일한 위치에 저장할 경우, 사용자 인증 절차를 우회할 수 있음을 보였다.

Ⅳ. iCloud 인증 정보 추출 및 활용 방법

이 절에서는 iCloud 2단계 인증을 우회할 수 있는 사용자 인증 정보를 추출하는 방법에 대해 언급하고, 이를 반영한 디지털포렌식 수사 절차를 소개한다. 아래 〈Figure 4〉는 본 논문에서 제안하는 iCloud 인증 정보 추출 및 사용자 행위 데이터 획득 절차에 대한 종합 순서도를 나타낸다. 이 절에 소개된 모든 기술 및 절차는 Windows 환경 및 Google Chrome 브라우저를 기준으로 설명한다.



〈Figure 4〉 Workflow for extracting iCloud authentication information and using them to access remote data

4.1. 인증 정보 추출

본 논문에서 제시하는 iCloud 인증 정보 추출 방법은 활성 상태 시스템과 비활성 상태 시스템을 구분하여 정의한다. 그리고 각각의 시스템 유형은 로컬 저장소와 메모리 분석 관점에서 인증 정보 추출 방법이 달라진다. 활성 상태 시스템이란, 현장에서 확보한 컴퓨터가 켜져 있는 상태를 의미하며 관리자 권한을 획득할 수 있는 상황을 가정한다. 반면, 비활성 상태 시스템은 컴퓨터가 꺼져있는 상태로 수사관이 로컬 저장소에 대한 이미지 사본을 획득한 상황을 가정한다.

4.1.1. 활성 상태 시스템의 로컬 저장소에서 iCloud 인증 정보를 추출하는 방법

활성 상태 시스템의 로컬 저장소에서 추출할 수 있는 iCloud 인증 정보는 1단계 인증 정보(ID, 비밀번호), 브라우저 신뢰토큰 그리고 PCS 세션 정보이다. 1단계 인증 정보는 사용자가 웹 브라우저에 "비밀번호 저장" 기능을 설정하였을 경우, 확인할 수 있으며 브라우저 신뢰토큰은 2단계 인증 이후 나타나는 신뢰토큰 발급 페이지에서 사

용자가 "신뢰함" 버튼을 클릭하였을 경우 획득할 수 있다. PCS 세션 정보는 1단계 인증 페이지에서 "로그인 상태 유지" 옵션을 체크한 후, 로그인했을 경우 로컬 저장소에 남게 되어 추출할 수 있다.

Google Chrome을 비롯한 크로미움 브라우저는 1단계 인증 정보(ID/비밀번호)를 Login Data 파일에 저장하고, 브라우저 신뢰토큰과 PCS 세션 정보는 Cookies 파일에 저장한다. 해당 인증 정보는 모두 AES-GCM으로 암호화되어 있으며 암호키는 Local State 파일의 "encrypted_key" 값에 DPAPI로 암호화된 상태로 존재한다. 따라서 수사관은 CryptUnprotectData API를 사용하여 Local State 파일에 저장된 암호키를 먼저 복호화한 후, 해당 키를 사용하여 AES-GCM 복호화를 통해 Login Data 및 Cookies 파일에서 iCloud 인증 정보를 추출한다. 아래 〈Table 3〉은 관련된 파일들의 경로를 나타낸 것이다. Login Data 및 Cookies 파일의 경우, 크로미움 브라우저에 등록된 사용자 계정에 따라 경로가 달라진다. 기본 계정일 경우, Default 폴더에 파일이 생성되며 계정이 여러 개 존재하면, Profile N 형식으로 개별 폴더가 만들어진다.

〈Table 3〉 File paths of Google Chrome's artifacts relating to iCloud authentication information

No.	iCloud authentication information file path	Description
1	%LocalAppdata%\Google\Chrome\User Data\{Default or Profile N}\Login Data	Login Data
2	%LocalAppdata%\Google\Chrome\User Data\{Default or Profile N}\Network\Cookies	Cookies
3	%LocalAppdata%\Google\Chrome\User Data\Local State	Local State

iCloud 계정 ID는 Login Data 파일 내 "logins" 테이블의 "username_value" 필드에 평문으로 존재하지만, 비밀번호는 같은 테이블의 "password_value" 필드에 AES-GCM으로 암호화 되어 저장된다. 기본적으로 iCloud 계정 정보는 "origin_url"이 "idmsa.apple.com/appleauth/auth/authorize/signin"이지만 사용자가 임의로 지정할 수도 있다.

한편, 브라우저 신뢰토큰 및 PCS 세션 정보는 Cookies 파일 내 "cookies" 테이블의 "encrypted_value" 필드에 AES-GCM으로 암호화 되어 저장된다. 해당 데이터들은 고유 이름이 존재하며 "X-APPLE"이라는 문자열로 시작하는 것이 특징이다. 아래 〈Table 4〉는 Cookies 파일에 저장되는 iCloud 인증 정보를 나타낸 것이다.

〈Table 4〉 iCloud authentication information stored in Google Chrome's Cookies database

No.	Name	Description	Condition
1	X-APPLE-WEBAUTH-HSA-TRUST	브라우저 신뢰토큰	"신뢰함" 버튼 클릭
2	X-APPLE-WEBAUTH-USER	필수 PCS 세션	"로그인 상태 유지" 설정
3	X-APPLE-WEBAUTH-TOKEN	필수 PCS 세션	"로그인 상태 유지" 설정
4	X-APPLE-WEBAUTH-PCS-Cloudkit	iCloud Cloudkit PCS 세션	"로그인 상태 유지" 설정
5	X-APPLE-WEBAUTH-PCS-Documents	iCloud Drive PCS 세션	"로그인 상태 유지" 설정
6	X-APPLE-WEBAUTH-PCS-Mail	iCloud Mail PCS 세션	"로그인 상태 유지" 설정
7	X-APPLE-WEBAUTH-PCS-News	iCloud News PCS 세션	"로그인 상태 유지" 설정
8	X-APPLE-WEBAUTH-PCS-Notes	iCloud Notes PCS 세션	"로그인 상태 유지" 설정
9	X-APPLE-WEBAUTH-PCS-Photos	iCloud Photos PCS 세션	"로그인 상태 유지" 설정
10	X-APPLE-WEBAUTH-PCS-Safari	iCloud Safari PCS 세션	"로그인 상태 유지" 설정
11	X-APPLE-WEBAUTH-PCS-Sharing	iCloud Sharing PCS 세션	"로그인 상태 유지" 설정

4.1.2. 활성 상태 시스템의 메모리 분석을 통해 iCloud 인증 정보를 추출하는 방법

활성 상태 시스템의 메모리 덤프 또는 페이지 파일(pagefile.sys) 추출이 가능한 경우, 수사관은 문자열 검색 및 Yara 룰을 활용하여 iCloud 계정 ID, 브라우저 신뢰토큰 그리고 PCS 세션 정보를 추출할 수 있다. 활성 상태 시스템을 대상으로 물리 메모리를 덤프하고 페이지 파일을 추출하기 위해서 활용할 수 있는 다양한 소프트웨어가 존재하며, 본 연구에서는 Magnet DumpIt과 FTK Imager를 사용하였다[13][14]. 참고로 물리 메모리 및 페이지 파일 내에는 압축된 상태로 저장된 페이지(page)가 존재할 수 있으므로, 인증 정보에 대한 패턴 검색을 시도하기 이전에 개별 페이지에 대한 압축 해제를 시도할 필요가 있다[15].

〈Table 2〉의 iCloud 1단계 인증 Internal API(signin)는 계정 ID와 비밀번호를 평문으로 넣어 POST 요청을 보내는 구조를 가지고 있다. 그러나 2024년 4월 현재, iCloud 웹사이트는 평문 비밀번호를 전송하는 방식의 로그인 API가 아닌, 암호화된 데이터를 전송하는 새로운 로그인 API를 활용하고 있다. 〈Table 5〉는 변경된 로그

인 API의 요청 구조를 나타낸 것이다. 결과적으로, 메모리상에서 계정 비밀번호를 패턴화를 통해 탐색할 수 없게 되었다. 하지만 iCloud 계정 ID, 브라우저 신뢰토큰 그리고 PCS 세션 정보는 여전히 패턴화가 가능하기 때문에 추출할 수 있다. 아래 〈Table 6〉은 iCloud 인증 정보 추출을 위한 정규 표현식을 나타낸 것이다.

〈Table 5〉 A newly added internal API for passing encrypted authentication information

No.	Request information		Description
1	URL	idmsa.apple.com/appleauth/auth/signin/complete	변경된 iCloud 1단계 인증 API (계정 비밀번호를 암호화하여 POST 데이터에 첨부)
	POST	{ "accountName" : iCloud 계정 ID, "c" : iCloud 계정 비밀번호 관련 암호화 데이터, "m1" : iCloud 계정 비밀번호 관련 암호화 데이터, "m2" : iCloud 계정 비밀번호 관련 암호화 데이터, "trustTokens" : 브라우저 신뢰토큰 }	

〈Table 6〉 Regular expressions for detecting iCloud authentication information

No.	Reqular expression	Description
1	/\{\"accountName\"\:\"[a-zA-Z0-9+-_.]+@[a-zA-Z0-9-]+\.[a-zA-Z0-9.]+.+\"trustTokens\"\:\[\"[^"\s,]+\"\]/	iCloud 계정 ID 및 브라우저 신뢰토큰 탐지
2	/X-APPLE-WEBAUTH-[^"\s,]+\"[^"\s,]+\"/	iCloud PCS 세션 탐지
3	/\{\"dsWebAuthToken\"\:\"[^"\s,]+\"/	iCloud PCS 세션 요청 POST 데이터 탐지

사용자가 과거에 브라우저 신뢰토큰을 발급받았을 경우, 클라이언트는 iCloud 로그인을 시도할 때 계정 ID와 브라우저 신뢰토큰을 하나의 JSON 데이터에 담아 서버로 전달하게 된다. 즉, 요청을 보내는 JSON 키를 활용하여 Yara 룰을 설계할 수 있다. 〈Table 6〉의 "accountName"은 iCloud 계정 ID를, "trustTokens"는 브라우저 신뢰토큰을 의미한다.

PCS 세션은 모두 "X-APPLE-WEBAUTH" 문자열로 시작하며 필수 세션 2개와 각 서비스를 담당하는 고유 세션 8개로 구분된다. 필수 세션이란, iCloud 계정과 연동되어있는 다른 서비스(iCloud Drive, iCloud Mail 등)에 접근할 때 공통적으로 넣게 되는 세션을 의미하며 "X-APPLE-WEBAUTH-USER"와 "X-APPLE-WEBAUTH-TOKEN" 세션이 이에 해당한다. 모든 iCloud 서비스는 필수 세션과 고유 세션을 같이 첨부하여 API 통신을 하게 된다. 따라서 시작하는 문자열을 활용하여 정규 표현식을 설계할 수 있다.

한편, PCS 세션을 요청하기 바로 전 단계의 API 흔적을 탐지하여 PCS 세션을 다시 요청할 수 있다. 〈Table 6〉의 "dsWebAuthToken"은 최종 로그인 인증 API(〈Table 2〉의 4번)의 POST 데이터의 키 값을 의미한다. iCloud Internal API는 〈Table 2〉와 같이 기본적으로 4번의 API 호출을 통해 사용자 인증을 완료하는데 API를 요청 시 "X-Apple-Session-Token" 값을 발급받아 갱신하는 특징을 가지고 있다. 즉, 1단계 인증을 통과하면 해당 쿠키를 서버로부터 받게 되고, 2단계 인증도 통과하면 그 값이 새로운 값으로 바뀌게 된다. 결국 쿠키 값을 계속 갱신해 오다가 마지막 API 요청 시 "dsWebAuthToken"에 최신 값을 넣어 서버로 보내게 된다. 즉, 수사관이 해당 값을 메모리에서 찾을 수 있다면, API 재요청 보내 iCloud 서버로부터 PCS 세션을 다시 발급받을 수 있게 된다. 메모리상에는 "dsWebAuthToken" 문자열을 키로 사용하는 JSON 형태로 데이터가 존재하기 때문에 패턴화가 가능하다.

4.1.3. 비활성 상태 시스템의 로컬 저장소에서 iCloud 인증 정보를 추출하는 방법

비활성 상태 시스템의 로컬 저장소에서 추출할 수 있는 iCloud 인증 정보는 활성 상태 시스템과 동일하다. 비활성 상태 시스템의 경우, 2.1절 및 4.1.1절에서 다룬 방법을 적용하여 DPAPI 마스터키를 수동으로 획득한 후, 인증 정보를 추출한다.

4.1.4. 비활성 상태 시스템의 메모리 분석을 통해 iCloud 인증 정보를 추출하는 방법

비활성 상태 시스템에서는 하이버네이션 파일(hiberfill.sys)을 수집하여 iCloud 인증 정보를 추출한다. 디지털 포렌식 수사관은 비활성 상태 시스템 이미지에서 하이버네이션 파일을 획득하여 압축 해제 과정을 거친 후, 〈Table

6〉에 언급된 정규 표현식을 통해 iCloud 인증 정보를 획득한다. 이후 4.1.2절과 동일한 방법을 적용하여 iCloud 계정 ID, 브라우저 신뢰토큰, PCS 세션 정보를 획득한다.

4.2. 인증 정보 활용

이전 4.1절에서 iCloud 인증 정보 추출 방법에 대해 자세히 다뤘다. 이 절에서는 추출한 인증 정보를 활용하여 iCloud 2단계 인증을 우회하는 방법을 소개한다. 그리고 획득한 PCS 세션을 매개로 계정과 연동된 iCloud 서비스에 대한 사용자 데이터에 접근하는 방법을 설명한다.

4.2.1. iCloud 로그인 API 호출

본 논문에서 정의한 iCloud 인증 정보는 계정 ID, 비밀번호, 브라우저 신뢰토큰, PCS 세션 정보 그리고 "X-Apple-Session-Token" 값이다. 아래 〈Table 7〉은 iCloud 로그인에 필요한 인증 정보 및 POST 요청에 필요한 데이터 구조를 정리한 것이다.

〈Table 7〉 Request method of iCloud authentication Internal API

No.	Request information		Response data	Description
1	URL	idmsa.apple.com/appleauth/auth/signin	X-Apple-Session-Token	iCloud 1단계 인증 + 브라우저 신뢰토큰을 활용한 계정 로그인
	POST	{ "accountName" : iCloud 계정 ID, "password" : iCloud 계정 비밀번호, "trustTokens" : 브라우저 신뢰토큰 }		
2	URL	setup.iCloud.com/setup/ws/1/accountLogin	WEBAUTH 필수 세션 + 각 서비스 PCS 세션	iCloud 최종 로그인 + PCS 세션 요청
	POST	{ "dsWebAuthToken" : X-Apple-Session-Token }		
3	URL	setup.icloud.com/setup/ws/1/validate	각 서비스 PCS 세션	iCloud PCS 세션 재발급 요청
	POST	{ "X-APPLE-WEBAUTH-USER" : 필수 USER 세션, "X-APPLE-WEBAUTH-TOKEN" : 필수 TOKEN 세션 }		
4	URL	iCloud Internal API (iCloud Drive, iCloud Mail ...)	iCloud 각 서비스에 대한 사용자 데이터를 불러옴 iCloud Drive 관련 데이터 iCloud Mail 관련 데이터 iCloud Note 관련 데이터 iCloud Photo 관련 데이터 ...	iCloud 각 서비스에 대한 API 요청 시 쿠키 값에 발급받은 PCS 세션 값을 첨부
	GET	Internal API가 GET 메소드일 경우, 데이터를 넣지 않음		
	POST	iCloud 각 서비스의 Internal API마다 데이터 형식이 다름		
	Cookies	{ "X-APPLE-WEBAUTH-USER" : 필수 USER 세션, "X-APPLE-WEBAUTH-TOKEN" : 필수 TOKEN 세션, "X-APPLE-WEBAUTH-PCS-*" : 각 서비스 고유 세션, ... }		

〈Table 7〉의 1번 "idmsa.apple.com/appleauth/auth/signin" API는 iCloud 계정 ID, 비밀번호 그리고 브라우저 신뢰토큰을 수집할 수 있는 경우, 사용할 수 있다. 현재 iCloud 웹 서비스는 〈Table 5〉에 언급된 것처럼 iCloud 계정 비밀번호를 암호화하여 요청하는 변경된 API를 사용하지만, 계정 비밀번호 획득이 가능한 경우, 〈Table 7〉의 1번에 해당하는 기존 API를 그대로 활용할 수 있다. 즉, POST 데이터의 "accountName", "password", "trustToken" 값에 추출한 3가지 iCloud 인증 정보를 입력한 후, 서버에 요청을 보내 "X-Apple-Session-Token" 값을 획득한다.

〈Table 7〉의 2번 "setup.iCloud.com/setup/ws/1/accountLogin"은 iCloud 최종 로그인 Internal API를 의미하며 API 요청에 성공할 경우, PCS 세션 값을 획득할 수 있다. 해당 API는 "X-Apple-Session-Token" 값을 수집할 수 있는 경우 사용할 수 있으며 "X-Apple-Session-Token" 값은 〈Table 7〉의 1번 API를 호출하여 확보하거나 메모리상에서 정규 표현식을 통해 탐색할 수 있다. 결과적으로, POST 데이터의 "dsWebAuthToken"에 해당 토큰 값을 입력한 후, 서버에 요청을 보내 사용자 계정의 PCS 세션을 획득한다.

〈Table 7〉의 3번 "setup.icloud.com/setup/ws/1/validate" API는 필수 세션(X-APPLE-WEBAUTH-USER,

X-APPLE-WEBAUTH-TOKEN)의 유효성을 검증하는 API를 의미한다. 해당 API 요청에 성공할 경우, iCloud 계정과 연동된 각 서비스의 PCS 고유 세션을 다시 발급받을 수 있다. 즉, 로컬 저장소 및 메모리 분석을 통해 위의 필수 세션 2개만 탐지할 수 있다면, 모든 PCS 세션을 재발급받아 iCloud 사용자 데이터에 접근할 수 있게 된다.

앞서 언급한 방법을 통해 PCS 세션을 획득한 경우, 이를 쿠키 값으로 첨부하여 iCloud Drive 및 Mail과 같은 서비스의 Intetnal API를 사용할 수 있다. PCS 세션은 필수 세션 2개와 특정 서비스에 해당하는 고유 세션 1개가 최소한으로 필요하며 고유 세션은 여러 개가 혼합되어도 무관하다. 즉, 최소 3개의 세션 정보를 로컬 저장소 또는 메모리상에서 추출하거나 〈Table 7〉의 1~3번 API 요청을 통해 재발급받을 수 있다면, 〈Table 7〉의 4번 형식처럼 각 서비스에 대한 Internal API를 사용하여 사용자 데이터에 접근할 수 있다.

4.2.2. 사용자 데이터 접근

이 절에서는 PCS 세션을 매개로 사용할 수 있는 API의 예시로 iCloud Drive와 Mail 서비스를 살펴본다. 〈Table 8〉과 〈Table 9〉는 두 서비스에 대한 Internal API를 정리한 것이다[7]. 각 서비스의 API는 p{N}으로 시작하며 N은 버전을 의미한다. 2024년 4월 현재 iCloud Drive의 API 버전은 125이고, iCloud Mail API의 버전은 31이다. 즉, 〈Table 8〉, 〈Table 9〉에 언급된 Internal API는 각각 “p125”, “p31”로 시작한다.

iCloud Drive의 경우, 필수 세션 2개와 “X-APPLE-WEBAUTH-PCS-Documents” 세션을 사용하여 원격지 내 파일의 메타데이터(타임스탬프, 크기 등)를 조회하거나 다운로드하는 등 iCloud Drive 관련 API를 사용할 수 있다.

iCloud Mail의 경우, 필수 세션 2개와 “X-APPLE-WEBAUTH-PCS-Mail” 세션을 사용하여 사용자가 송수신한 메일 및 삭제한 메일에 대한 메타데이터(메일의 제목(Title), 식별자(guid), 타임스탬프 등)를 확인할 수 있다. 또한 메일의 식별자(guid)를 활용하여 메일의 원본 데이터를 요청하거나 첨부파일을 별도로 다운로드할 수 있다.

〈Table 8〉 Internal APIs for accessing iCloud Drive related data

No.	iCloud Internal API URL	Description
1	p{N}-drivews.icloud.com/retrieveItemDetailsInFolders	폴더 내 하위 파일에 대한 메타데이터 확인
2	p{N}-drivews.icloud.com/retrieveItemDetails	단일 파일 및 폴더에 대한 메타데이터 확인
3	p{N}-drivews.icloud.com/moveItemsToTrash	선택한 파일을 드라이브 내 휴지통으로 이동
4	p{N}-drivews.icloud.com/deleteItems	선택한 파일 삭제
5	p{N}-drivews.icloud.com/putBackItemsFromTrash	선택한 파일을 휴지통에서 복구
6	p{N}-docws.icloud.com/ws/com.apple.CloudDocs/download/batch	선택한 파일의 다운로드 링크 확인

〈Table 9〉 Internal APIs for accessing iCloud Mail related data

No.	iCloud Internal API URL	Description
1	p{N}-mailws.icloud.com/wm/message	전체 메일의 메타데이터 확인
2	p{N}-mailws.icloud.com/wm/message/{Title}.eml?guid={guid}	선택한 메일 원본 데이터 확인
3	p{N}-mailws.icloud.com/{Attachment file download URL}	선택한 메일의 첨부파일 다운로드

Ⅴ. 실험 및 결과

이 절에서는 4절에서 제시한 방법론을 활용할 수 있는 가상 시나리오를 구성하고, 9가지 평가 문항을 통해 방법론의 타당성 및 실현 가능성을 종합적으로 평가한다. 가상 시나리오 내용은 아래와 같다. 〈Table 10〉은 이에 대한 평가 결과를 나타낸 것이다. 평가 결과의 만족 여부가 “○”인 경우, 평가 문항에 제시된 내용을 모두 이행할 수 있음을 의미한다. 만족 여부가 “△”인 경우, 평가 문항에 제시된 내용을 부분적으로 이행할 수 있음을 의미한다. 즉, 평가 문항에 언급된 iCloud 인증 정보를 몇 개만 제한적으로 추출할 수 있는 경우, “△”를 부여한다. 만족 여부가 “×”인 경우, 평가 문항에 제시된 내용을 모두 이행할 수 없음을 의미한다.

1) 활성 상태 시스템 시나리오: 회사원 A씨가 자사 기밀문서인 “Case_A.pdf”를 유출하려는 의심 정황이 포착되어 수사 의뢰가 들어왔다. A씨는 Chrome 브라우저를 통해 iCloud에 로그인한 후, iCloud Drive에 해당 파일을 업로드했다. A씨는 평소 Chrome 브라우저 “비밀번호 저장” 기능을 사용하여 iCloud 계정 ID와 비밀번호를

저장해두고, 브라우저 신뢰토큰을 발급받아 사용한다. 현장의 A씨 컴퓨터는 켜져 있는 상태이다.

2) 비활성 상태 시스템 시나리오: 회사원 B씨가 직원들의 개인 정보가 담긴 “Case_B.xlsx” 문서를 불법 거래에 사용했다는 신고가 들어왔다. B씨는 Brave 브라우저를 통해 iCloud에 로그인 및 브라우저 신뢰토큰을 발급받은 후, iCloud Mail에 접속하여 해당 문서를 메일의 첨부파일에 담아 전송했다. B씨는 개인 정보에 민감하여 회사 컴퓨터에 iCloud 계정 ID와 비밀번호를 저장하지 않는다. 현장의 B씨 컴퓨터는 꺼져있는 상태이다.

〈Table 10〉 Scenario Evaluation Criteria and Results

No.	시나리오 구분	평가 문항	만족 여부(O/△/×)
1	활성 상태	로컬 저장소 분석을 통해 1단계 인증 정보(ID/비밀번호)를 획득할 수 있는가?	O
2	비활성 상태	하이버네이션 파일 분석을 통해 1단계 인증 정보(ID/비밀번호)를 획득할 수 있는가?	△
3	활성 상태	물리 메모리 덤프를 통해 브라우저 신뢰토큰을 획득할 수 있는가?	O
4	비활성 상태	로컬 저장소 분석을 통해 브라우저 신뢰토큰을 획득할 수 있는가?	O
5	활성 상태	물리 메모리 덤프를 통해 X-Apple-Session-Token을 획득할 수 있는가?	O
6	활성 상태	물리 메모리 덤프를 통해 PCS 세션을 획득할 수 있는가?	O
7	비활성 상태	하이버네이션 파일 분석을 통해 PCS 세션을 획득할 수 있는가?	O
8	활성 상태	2단계 인증을 우회하여 iCloud Drive 데이터에 접근할 수 있는가?	O
9	비활성 상태	2단계 인증을 우회하여 iCloud Mail 데이터에 접근할 수 있는가?	O

5.1. 〔활성 상태〕 로컬 저장소 분석을 통해 1단계 인증 정보(ID/비밀번호)를 획득할 수 있는가? (O)

활성 상태 시스템 시나리오에서 사용자는 Chrome 브라우저를 통해 iCloud 계정 ID와 비밀번호를 저장했다. 따라서 Local State 파일에 저장되어 있는 암호키를 CryptUnprotectData를 통해 획득한 후, Login Data 파일에 존재하는 iCloud 계정 ID와 비밀번호를 복호화하여 수집한다.

5.2. 〔비활성 상태〕 하이버네이션 파일 분석을 통해 1단계 인증 정보(ID/비밀번호)를 획득할 수 있는가? (△)

비활성 상태 시스템 시나리오에서 사용자는 Brave 브라우저를 통해 iCloud에 로그인했다. 그러나 계정 ID와 비밀번호를 저장하지 않았기 때문에 로컬 저장소에서 1단계 인증 정보를 획득할 수 없다. 하지만 Windows 환경의 “빠른 시작 켜기” 옵션이 활성화되어 있는 경우, 시스템 종료 시 하이버네이션 파일이 생성되기 때문에 이를 분석하여 iCloud 로그인 흔적을 탐색할 수 있다〔11〕〔17〕. 〈Figure 5〉는 하이버네이션 파일에서 탐지된 iCloud 인증 정보를 나타낸 것이다. 〈Figure 5〉에서 iCloud 계정 ID 및 브라우저 신뢰토큰은 확인할 수 있지만 계정 비밀번호는 획득할 수 없다.

〈Figure 5〉 iCloud account ID and browser trust token detected within hiberfil.sys

5.3. 〔활성 상태〕 물리 메모리 덤프를 통해 브라우저 신뢰토큰을 획득할 수 있는가? (O)

활성 상태 시스템 시나리오에서 사용자는 Chrome 브라우저를 통해 iCloud에 로그인했고, 브라우저 신뢰토큰을 발급받았다. 따라서 물리 메모리 덤프 및 페이지 파일(pagefile.sys) 추출을 통해 이에 대한 아티팩트를 수집할 수 있다. 브라우저 신뢰토큰은 〈Figure 5〉와 같이 “trustTokens” 형태로 남게 된다.

5.4. 〔비활성 상태〕 로컬 저장소 분석을 통해 브라우저 신뢰토큰을 획득할 수 있는가? (O)

비활성 상태 시스템 시나리오에서 사용자는 Brave 브라우저를 사용하여 iCloud 브라우저 신뢰토큰을 발급받았다. Brave의 경우, 브라우저 신뢰토큰은 〈Table 11〉의 Cookies 파일에 저장되며 DPAPI 복호화를 통해 이를 획득할 수 있다. 비활성 상태 시스템에서 DPAPI 암호화 데이터의 복호화 순서는 다음과 같다.

1) 비활성 이미지로부터 SAM, SYSTEM 레지스트리를 추출하여 NTLM 해시를 계산한다.
2) hashcat〔16〕을 활용한 NTLM 해시 크래킹을 통해 Microsoft 계정 비밀번호를 획득한다.
3) 획득한 계정 비밀번호를 통해 Microsoft CacheData 파일을 복호화한 후, SHA-1 해시를 계산한다.
4) SHA-1 해시, SID 값, GUID 파일을 이용하여 비활성 상태 시스템의 DPAPI 마스터키를 획득한다.
5) DPAPI 마스터키를 통해 Local State 파일에 저장된 암호키를 복호화한다.
6) 복호화한 암호키를 활용하여 Cookies 파일에 저장된 브라우저 신뢰토큰을 획득한다.

〈Table 11〉 File paths of Brave's artifacts relating to iCloud authentication information

No.	iCloud authentication information file path	Description
1	%LocalAppdata%\BraveSoftware\Brave-Browser\User Data\{Default or Profile N}\Network\Cookies	Cookies
2	%LocalAppdata%\BraveSoftware\Brave-Browser\User Data\Local State	Local State

아래 〈Figure 6〉은 비활성 상태 시스템에서 Brave에 저장된 iCloud 브라우저 신뢰토큰을 복호화한 예시이다. NTLM 해시 크래킹을 통해 Microsoft 계정 비밀번호를 확보할 수 있다면, CacheData 복호화를 통해 DPAPI 마스터키 계산이 가능하다. 그리고 이를 활용하여 Cookies 파일에 저장된 브라우저 신뢰토큰을 추출할 수 있다. 브라우저 신뢰토큰은 "X-APPLE-WEBAUTH-HAS-TRUST" 값을 의미하며 유효기간은 약 3달 정도이다.

〈Figure 6〉 Decryption steps of DPAPI-protected 'browser trust token' stored on a Windows system with a Microsoft account

5.5. 〔활성 상태〕 물리 메모리 덤프를 통해 X-Apple-Session-Token을 획득할 수 있는가? (O)

활성 상태 시스템 시나리오에서 사용자는 Chrome 브라우저를 통해 iCloud에 로그인했기 때문에 〈Table 7〉의 2번 인증 과정에 대한 "X-Apple-Session-Token" 값이 메모리상에 남아있다. 따라서 메모리 덤프를 한 후, 〈Table 6〉의 3번 정규 표현식을 활용하여 해당 토큰 값을 탐색한다. 〈Figure 7〉은 메모리상에서 탐지된 "X-Apple-Session-Token"의 예시이다.

5.6. [활성 상태] 물리 메모리 덤프를 통해 PCS 세션을 획득할 수 있는가? (O)

활성 상태 시스템 시나리오에서 사용자는 Chrome 브라우저를 통해 iCloud에 로그인한 후, iCloud Drive에 접속했다. 따라서 메모리상에 PCS 세션에 대한 흔적이 존재한다. <Figure 7>은 메모리상에서 탐지된 PCS 세션의 예시이다.

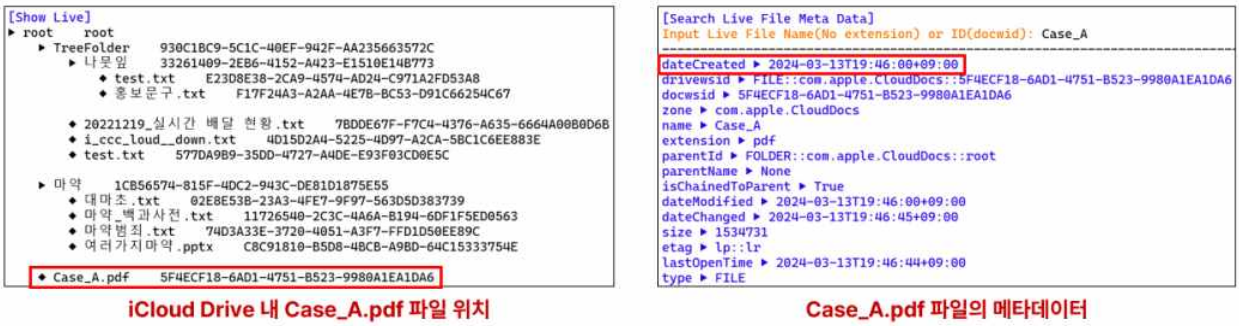
<Figure 7> iCloud sessions detected within memory dump file

5.7. [비활성 상태] 하이버네이션 파일 분석을 통해 PCS 세션을 획득할 수 있는가? (O)

비활성 상태 시스템 시나리오에서 사용자는 Brave 브라우저를 통해 iCloud에 로그인한 후, 시스템을 종료했다. 따라서 5.2절과 같은 방법으로 비활성 이미지로부터 하이버네이션 파일을 추출하여 압축 해제한 후, PCS 세션 정보를 탐색할 수 있다. 해당 세션 정보는 <Figure 7>과 같은 형식으로 남게 된다.

5.8. [활성 상태] 2단계 인증을 우회하여 iCloud Drive 데이터에 접근할 수 있는가? (O)

이전 5.1절과 5.3절에서 iCloud 1단계 인증 정보(ID/비밀번호) 및 브라우저 신뢰토큰을 로컬 저장소에서 추출할 수 있음을 보였다. 또한 5.5절과 5.6절에서 "X-Apple-Session-Token" 값과 PCS 세션 정보가 메모리 덤프 파일에서 탐지될 수 있음을 확인했다. 따라서 수사관은 <Table 7>의 1~3번 방법을 적용하여 iCloud 사용자 계정에 대한 PCS 세션을 다시 발급받을 수 있다. 그리고 이를 매개로 iCloud Drive에 접근하여 "Case_A.pdf" 파일에 대한 정보를 획득할 수 있다. 아래 <Figure 8>은 원격지 내의 "Case_A.pdf" 파일에 대한 메타데이터를 출력한 것이다. 해당 파일은 UTC+9를 기준으로 2024년 3월 13일 19시 46분에 업로드되었다는 사실을 알 수 있다.



<Figure 8> Accessing metadata of a sample PDF file stored in iCloud Drive

5.9. 〔비활성 상태〕 2단계 인증을 우회하여 iCloud Mail 데이터에 접근할 수 있는가? (O)

5.2절과 5.4절에서 비활성 상태 시스템의 로컬 저장소 및 하이버네이션 파일 분석을 통해 iCloud 계정 ID 및 브라우저 신뢰토큰 추출이 가능함을 확인했다. 그러나 iCloud 계정 비밀번호를 획득할 수 없어 〈Table 7〉의 1번 방법을 적용하기는 어렵다. 하지만 5.7절에서 PCS 세션 정보를 하이버네이션 파일 내에서 추출할 수 있었기 때문에 〈Table 7〉의 3번 방법을 적용할 수 있다. 즉, 사용자 계정에 대한 모든 PCS 세션 정보를 API 요청을 통해 다시 발급받을 수 있다. 그리고 이를 매개로 iCloud Mail에 접근하여 "Case_B.xlsx" 파일의 전송 여부를 확인할 수 있다. 아래 〈Figure 9〉는 보낸 메일함에서 발견된 "Case_B.xlsx" 첨부 메일의 정보를 나타낸 것이다. 사용자는 UTC+9를 기준으로 2024년 3월 13일 20시 13분에 해당 파일을 전송했음을 알 수 있다.

```
[Show Sent_Messages]

■ Sent_Messages Count: 8
--------------------------------------------------------------------------------
● Index: 1
● Timestamp: 2024-03-13T20:13:15+09:00
● guid: message:Sent Messages/10
● folder: folder:Sent Messages
● Recipient: ['[redacted]@[redacted]']
● Sender: [redacted] <[redacted]@[redacted]>
● Title: [Secret] 개인 정보
● PreviewId: 10-1
● Preview: 회사 내부 직원 개인정보 입니다.
● HasAttachment: True
    ▶ Attachment Name: Case_B.xlsx
    ▶ Attachment guid: messagepart:Sent Messages/10-2.2
    ▶ Attachment Size: 723798
    ▶ Download URL: /wm/messagepart/Case_B.xlsx?guid=messagepart%3ASent%20Messages%2F10-2.2&type=application
%2Fvnd.openxmlformats-officedocument.spreadsheetml.sheet&name=Case_B.xlsx&size=723798
● NumOfAttachment: 1
```

iCloud Mail의 보낸 메일함 내 Case_B.xlsx 첨부 메일

〈Figure 9〉 Accessing a sample email with an attachment stored in iCloud Mail

Ⅵ. 결론 및 향후 발전 방향

본 연구에서는 Windows 환경의 활성 및 비활성 상태의 시스템 관점에서 iCloud 2단계 인증을 우회할 수 있는 인증 정보 추출 방법론을 제안하고, 가상 시나리오 구성 및 평가를 통해 절차의 타당성과 실현 가능성을 입증했다. 본 연구에서 다룬 방법론을 디지털포렌식 수사에 도입한다면, 수사관이 iCloud 사용자 데이터에 접근할 수 있는 가능성이 높아져 보다 정밀한 수사가 가능해질 것이다.

본 논문은 Windows 환경에서의 iCloud 웹 서비스를 기준으로 작성되었다. iCloud는 Linux 및 macOS 환경에서도 지원되며 iCloud for Windows〔18〕와 같은 데스크톱 앱으로도 출시가 될 만큼 호환성이 뛰어난 서비스이다. 또한 Android, iOS와 같은 모바일 분야에서도 널리 사용되기 때문에 방법론의 연구 범위의 확장이 필요하다. 따라서 다양한 운영체제 환경 및 모바일, 데스크톱 앱에 대해 iCloud 2단계 인증을 우회할 수 있는 사용자 인증 정보 추출 및 활용에 관한 연구를 지속할 계획이다.

더 나아가, iCloud를 비롯한 다양한 온라인 서비스를 대상으로 인증 API의 동작 원리와 로컬 시스템에 잔존 가능한 인증 정보를 체계적으로 추출하는 기법을 연구하고, 이러한 지식을 계속해서 축적해 나간다면, 디지털포렌식 수사 관점에서 사용자 로그인 권한 획득 및 행위 분석을 보다 고도화할 수 있을 것이다. 따라서 향후 발전 방향으로 본 연구의 방법론을 다른 온라인 서비스에서도 적용할 수 있도록 일반화하는 연구를 추가적으로 진행할 예정이다.

참 고 문 헌 (References)

〔1〕 MAGNET Forensics, MAGNET AXIOM, Available: https://www.magnetforensics.com/, 2024.03.17. confirmed.

〔2〕 Burzstein, E., and Picod, J. M., "Recovering Windows Secrets and {EFS} Certificates Offline.", 4th USENIX Workshop on Offensive Technologies (WOOT 10), 2010.

〔3〕 Fortra, Impacket, Available: https://github.com/fortra/impacket/, 2024.03.17. confirmed.

〔4〕 Sirgiannis, M. A., Manifavas, C., and Papaefstathiou, I., "Making Citizens' systems more Secure: Practical Encryption Bypassing and Countermeasures.", IEEE Symposium on Computers and Communications (ISCC), 2022.

〔5〕 NirSoft, MadPassExt, Available:https://www.nirsoft.net/utils/microsoft_account_dpapi_password.html/, 2024.03.17. confirmed.

〔6〕 Jihyeok, Y., Jieon, K., Jewan, B., Sangjin, L., and Jungheum, P., "Catch: cloud data acquisition through comprehensive and hybrid approaches.", Forensic Science International: Digital Investigation, 43, 2022.

〔7〕 MauriceConrad, iCloud API, Available: https://github.com/MauriceConrad/iCloud-API/, 2024.03.17. confirmed.

〔8〕 Oestreicher, K., "A forensically robust method for acquisition of iCloud data.", Digital Investigation, 11, S106-S113, 2014.

〔9〕 Ahmad, N. H., Hamid, A. S. S. A., Shahidan, N. S. S., and Ariffin, K. A. Z., "Cloud forensic analysis on pCloud: From volatile memory perspectives.", Emerging Technologies in Computing: Third EAI International Conference (iCETiC), London, UK, August 19–20, 2020.

〔10〕 Oracle, VirtualBox, Available: https://www.virtualbox.org/, 2024.03.17. confirmed.

〔11〕 Sumin, B., Philgeun, J., Donghyun, K., Jungheum P., Sangjin L., Aran, P., and Ilhoon, J., "A Study on Utilization of Windows 10 hiberfil.sys file for Digital Forensics", Journal of Digital Forensics, 15(1), 125-136, 2021.

〔12〕 Uk, H., Soojin, K., Giyoon, K., and Jongsung, K., "A study on cloud data access through browser credential migration in Windows environment.", Forensic Science International: Digital Investigation, 45, 2023.

〔13〕 MAGNET Forensics, MAGNET DumpIt, Available: https://www.magnetforensics.com/resources/magnet-dumpit-for-windows/, 2024.03.17. confirmed.

〔14〕 Exterro, FTK Imager, Available:https://www.exterro.com/ftk-product-downloads/ftk-imager-version-4-7-1, 2024.03.17. confirmed.

〔15〕 aleksost, MemoryDecompression, Available: https://github.com/aleksost/MemoryDecompression/, 2024.03.17. confirmed.

〔16〕 hashcat, Available: https://github.com/hashcat/hashcat/, 2024.03.17. confirmed.

〔17〕 ARSENAL, Hibernation Recon, Available: https://arsenalrecon.com/products/hibernation-recon/, 2024.03.17. confirmed.

〔18〕 Microsoft, iCloud for Windows, Available: https://apps.microsoft.com/detail/9pktq5699m62?hl=ko-KR&gl=KR/, 2024.03.17. confirmed.

저 자 소 개

김 재 욱 (Jaeuk Kim)
준회원

2022년 8월 : 서울시립대학교 수학과 졸업
2022년 9월 ~ 현재 : 고려대학교 일반대학원 정보보안학과 석사과정
관심분야 : 디지털포렌식, 역공학, 암호 알고리즘

김 준 호 (Junho Kim)
준회원

2020년 2월 : 고려대학교 정보보호대학원 공학석사
2020년 3월 ~ 현재 : 고려대학교 정보보호대학원 박사과정
관심분야 : 디지털포렌식, 인공지능, 침해사고대응

박 정 흠 (Jungheum Park)
정회원

2014년 2월 : 고려대학교 정보보호대학원 공학박사
2015년 1월 ~ 2019년 2월 : 미국 국립표준기술연구원(NIST) 방문연구원
2019년 3월 ~ 2021년 8월 : 고려대학교 정보보호연구원 연구교수
2021년 9월 ~ 2022년 2월 : 고려대학교 정보보호대학원 조교수
2022년 3월 ~ 현재 : 고려대학교 정보보호대학원 부교수
관심분야 : 디지털포렌식, 사이버범죄대응, 침해사고대응